

Caso práctico | Respuesta a incidentes

Preparado por: Jhonny Rene Valdivieso Pajon

Fecha: 20 de junio de 2026

Departamento: Equipo de Respuesta a Incidentes (Cybershield)

1. Resumen Ejecutivo

El presente informe documenta la investigación sobre una campaña de **Spear Phishing** dirigida a los empleados de Terra. Se identificó una intrusión que afectó al trabajador Rogelio, quien interactuó con un archivo malicioso, provocando una serie de eventos críticos en el SIEM que incluyeron escalación de privilegios, evasión de defensas, establecimiento de persistencia mediante Netcat y exfiltración de datos.

2. Identificación del Incidente

El incidente se clasifica como una campaña de Spear Phishing que derivó en una compromisión persistente y completa del host. El atacante no solo logró el acceso inicial mediante *masquerading* (`.pdf.exe`), sino que escaló privilegios y manipuló los controles de seguridad del sistema.

Las fases identificadas en el ataque incluyen:

- **Acceso Inicial:** Phishing dirigido con archivos ejecutables disfrazados.
- **Escalación de Privilegios:** Inclusión de una cuenta clon en el grupo de 'Administradores' para obtener control total sobre el sistema operativo.
- **Evasión de Defensas:** Desactivación completa del Firewall de Windows mediante scripts de PowerShell.

- **Persistencia:** Modificación de llaves de registro para asegurar la ejecución de Netcat (`nc.exe`) en cada reinicio, estableciendo una conexión inversa hacia una IP externa [89.44.9.243].
- **Impacto Final:** Exfiltración de datos detectada por los algoritmos de Machine Learning del SIEM.

3. Recolección de Evidencias

Para el análisis de este incidente, se han recopilado y documentado las siguientes pruebas forenses que sustentan el hallazgo de la intrusión:

3.1 Artefacto de Correo Electrónico

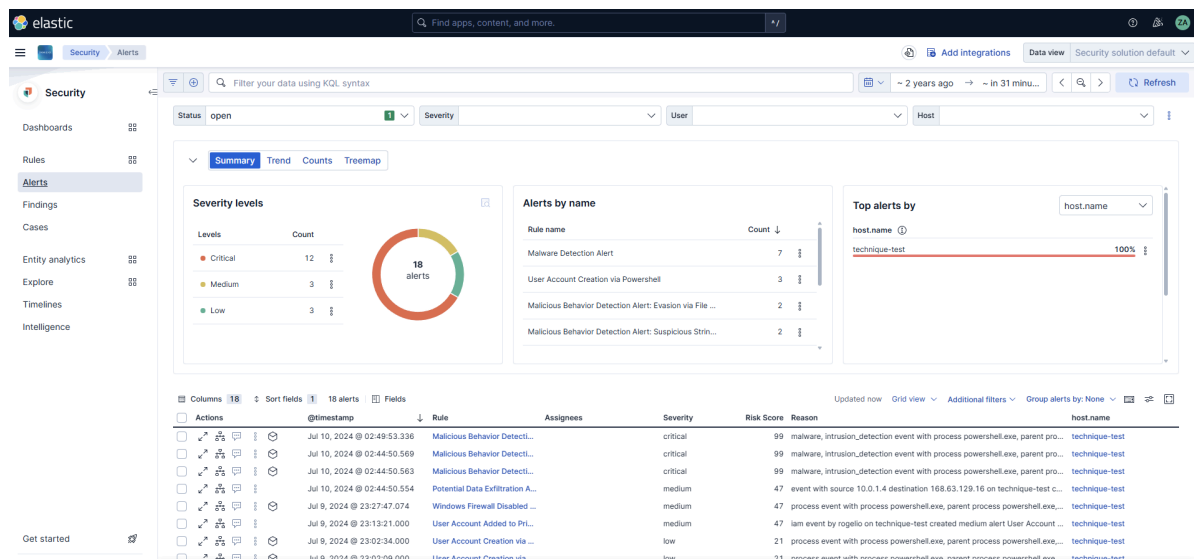
Se analizó el correo electrónico original recibido por el usuario, identificado bajo el archivo `;;Urgente!! Tu cuenta puede estar en peligro.eml` . Este archivo permitió extraer la estructura del ataque, confirmando el uso de un remitente apócrifo (`outluok.co`) y la URL de descarga maliciosa.

`;;Urgente!! Tu cuenta puede estar en peligro.eml`

3.2 Registros de Actividad

La telemetría de Elastic SIEM proporcionó el rastro técnico de la actividad maliciosa en el host del usuario Rogelio. Se documentaron eventos críticos de escalación de privilegios, modificación de llaves de registro para persistencia mediante `nc.exe` y la comunicación con una IP externa (89.44.9.243).

- **Figura 1: Elastic SIEM Dashboard.**



La correlación de estos eventos, desde el acceso inicial hasta la exfiltración de datos detectada por Machine Learning, demuestra una progresión de ataque planificada y de alta severidad que compromete la integridad y confidencialidad de los activos de Terra.

3.3 Documentación Visual

Las siguientes capturas ilustran los hallazgos técnicos registrados durante la investigación en IRIS:

- **Figura 2: Registro de logs del SIEM.**

Medium

Jul 9, 2024 @ 23:13:21.000

⚠️

User Account Added to Privileged Group

↗️

Status

Open

Risk score

47

Assignees

+

Notes

—

Overview

Table

JSON

▼ Investigation

📖

Show investigation guide

Highlighted fields

+ Add Field

Field	Value
group.name	Administrators
Source event	fG3FmZABRidmhXBI4wak
host.name	technique-test
user.name	rogelio
cloud.provider	azure
cloud.region	eastus2
kibana.alert.rule.type	eql

- **Figura 3: Línea de tiempo de la infección.**

7/8/2024

[21:44:02] Acceso Inicial: Detección de Malware en Papelera vía Outlook

Se identificó una alerta crítica de seguridad en Elastic SIEM a las 21:44:02. El proceso legítimo 'outlook.exe' (ejecutado bajo el perfil del usuario 'rogelio') generó la escritura de un binario malicioso en la ruta oculta de la Papelera de Reciclaje (C:\\$Recycle.Bin).

[See more](#)

5f7e5e76ca74447126ef5bccb0584342dc0890e1a65e4cac7f84281230df0728 Initial Access

acceso-inicial malware-detection phishing \$RD60126.exe

Rogelio (Windows Account - Local) PC de rogelio (Windows - Computer)

07/09/2024, 09:44:02 PM



[21:47:15] Evasión y Ejecución: Descarga y Activación de Binario vía Edge

Se detectó la descarga de un binario malicioso mediante 'msedge.exe' que utiliza la técnica de File Name Masquerading (T1036.003) con doble extensión (.pdf.exe). La telemetría concurrente confirma que el usuario interactuó con el archivo, registrándose inmediatamente como un proceso activo en la memoria del sistema operativo (process.name), completando la transición de un elemento pasivo en disco a una amenaza en ejecución.

[See more](#)

Defense Evasion

5f7e5e76ca74447126ef5bccb0584342dc0890e1a65e4cac7f84281230df0728

Execution masquerading msedge Historial_Pagos_Visa.pdf.exe

PC de rogelio (Windows - Computer) Defense Evasion

Rogelio (Windows Account - Local)

07/09/2024, 09:47:15 PM



[21:47:27] Ejecución de Comando: Establecimiento de Reverse Shell vía Netcat

Múltiples alertas concurrentes en el SIEM confirman la fase de ejecución de comandos y el intento de establecimiento de un canal de Comando y Control (C2). El binario malicioso principal extrajo y ejecutó la utilidad 'nc.exe' (Netcat) desde el directorio temporal 'C:\Users\rogelio\AppData\Local\Temp\3\

[See more](#)

nc.exe Command and Control

b3b207dfab2f429cc352ba125be32a0cae69fe4bf8563ab7d0128bba8c57a71c

netcat reverse-shell execution 89.44.9.243

PC de rogelio (Windows - Computer) c2-connection

Rogelio (Windows Account - Local)

07/09/2024, 09:47:27 PM

[23:02:06] Persistencia: Creación de Cuenta Local Maliciosa vía PowerShell

Habiendo establecido el canal de Comando y Control (C2), el atacante ejecutó comandos remotos para asegurar su persistencia en el host. La telemetría de Elastic SIEM registró la invocación de 'powershell.exe' ejecutando el cmdlet 'New-LocalUser'. El atacante forzó la creación de una cuenta local clon bajo el nombre de 'rogelio' (coincidente con el nombre del usuario legítimo de la víctima) y le asignó la contraseña estática 'password2 \$' mediante la conversión forzada de texto plano ('-AsPlainText -Force'), garantizando así un vector de acceso secundario y permanente en el sistema comprometido. Posteriormente, esta cuenta fue elevada al grupo de seguridad 'Administrators'.

[> See more](#)

Persistence * rogelio * password2\$ Persistence
Credential Compromised PowerShell Account Creation
PC de rogelio (Windows - Computer)

07/09/2024, 11:02:06 PM



[23:13:14] Escalación de Privilegios: Inclusión de Cuenta Clon en el Grupo de Administradores

Once minutos después de la creación de la cuenta local clonada, la telemetría de Elastic SIEM detectó una maniobra de escalación de privilegios en el host 'technique-test'. El atacante asignó la cuenta recién creada ('rogelio') al grupo de alta seguridad 'Administrators'. Esta acción otorga al adversario privilegios administrativos plenos sobre el sistema operativo, permitiéndole evadir controles locales de control de cuentas de usuario (UAC) e interactuar con componentes críticos del sistema.

[> See more](#)

Privilege Escalation * rogelio * password2\$ Privilege Escalation
PC de rogelio (Windows - Computer) EQL Azure Administrators

07/09/2024, 11:13:14 PM



[23:25:28] Evasión de Defensas: Desactivación Completa del Firewall de Windows vía PowerShell

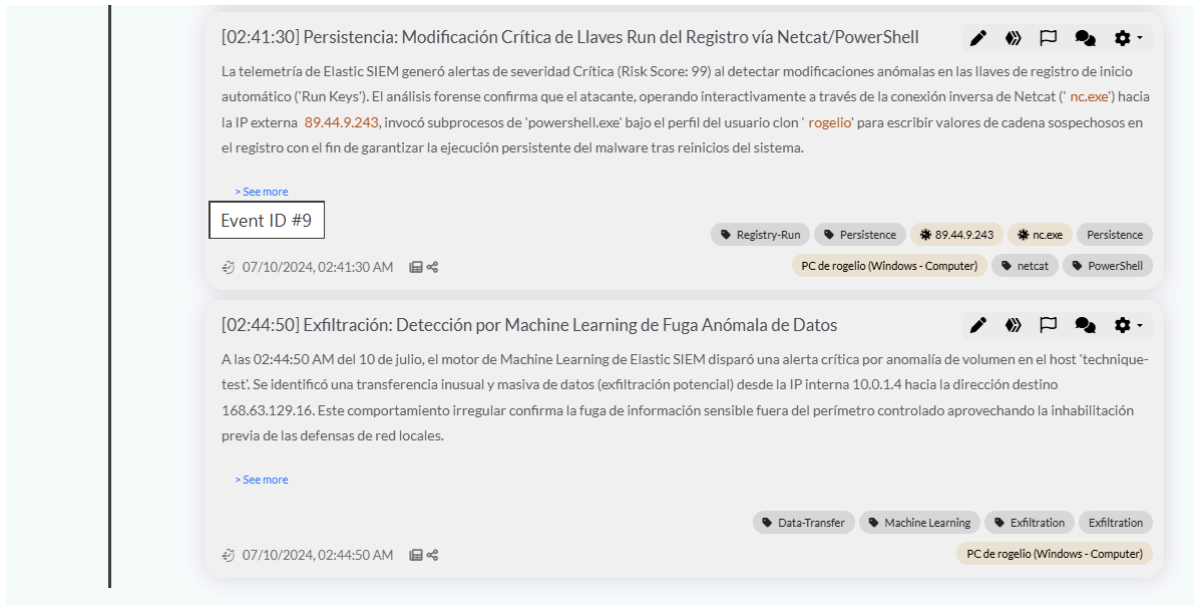
El atacante abusó de sus privilegios administrativos utilizando la cuenta clon 'rogelio' para degradar los controles de seguridad del host. La telemetría de Elastic SIEM registró la ejecución del cmdlet 'Set-NetFirewallProfile' con los argumentos '-Enabled False -All'. Esta acción desactiva por completo el Firewall de Windows en todos sus perfiles (Domain, Private, Public), eliminando las barreras perimetrales internas del sistema para permitir tráfico de red irrestricto.

[> See more](#)

* Set-NetFirewallProfile -Enabled False -All Defense Evasion
Firewall-Disabled PowerShell Defense Evasion
PC de rogelio (Windows - Computer)

07/09/2024, 11:25:28 PM





4. Indicadores de Compromiso (IoCs)

Se han extraído y validado los siguientes indicadores técnicos directamente de la telemetría del incidente. Estos deben ser utilizados para fortalecer las listas de bloqueo y reglas de detección de la organización.

Tipo	Valor	Descripción
Filename	Historial_Pagos_Visa.pdf.exe	Binario inicial utilizado para el engaño y <i>masquerading</i> .
Filename	\$RD60126.exe	Artefacto local creado tras la descarga.
Filename	nc.exe	Utilidad Netcat empleada para la conexión remota.
SHA256	5f7e5e...	Firma digital única del binario malicioso.
SHA256	b3b207...	Hash correspondiente al binario de Netcat.
IP-DST	89.44.9.243	Servidor de Comando y Control (C2).
Text	password2\$	Credencial estática utilizada para la persistencia.
Text	rogelio	Cuenta clonada para escalación de privilegios.

Text	<code>Set-NetFirewallProfile - Enabled False -All</code>	Comando de PowerShell para evasión de defensa.
------	--	--

5. Gestión del Incidente

El equipo de respuesta a incidentes llevó a cabo la gestión del caso siguiendo el marco estándar de respuesta a incidentes, logrando neutralizar la amenaza y asegurar el entorno afectado.

5.1 Identificación y Análisis

A través de la telemetría de Elastic SIEM, se correlacionaron los eventos desde el acceso inicial (phishing) hasta la exfiltración de datos. Se confirmó que el adversario obtuvo control administrativo completo sobre el host `technique-test` mediante la creación de una cuenta clon (`rogelio`) y la desactivación de las defensas perimetrales del equipo.

5.2 Contención

Se procedió con las siguientes acciones de contención inmediata para detener la comunicación maliciosa:

- **Bloqueo perimetral:** Se aplicaron reglas de filtrado en el Firewall para denegar cualquier tráfico hacia la IP del servidor de Comando y Control (C2) `89.44.9.243` .
- **Aislamiento:** El host afectado fue desconectado de la red corporativa para evitar la propagación del malware y la continuación de la exfiltración de datos `Insolate` .

5.3 Erradicación

Se ejecutaron las siguientes acciones para eliminar la persistencia del atacante:

- **Eliminación de artefactos:** Se borraron los archivos maliciosos identificados: `Historial_Pagos_Visa.pdf.exe` , `$RD60126.exe` y `nc.exe` .
- **Limpieza de cuentas:** Se eliminó la cuenta de usuario clon (`rogelio`) creada con privilegios administrativos y se restablecieron las contraseñas de todos los usuarios comprometidos.

- **Reversión de cambios:** Se revirtió la modificación de llaves de registro de inicio automático y se reactivó el Firewall de Windows mediante las políticas de grupo (GPO).

5.4 Recuperación

Tras la sanitización, se realizó un escaneo profundo de seguridad en el sistema, se validó la integridad de los servicios y se restauró el acceso controlado del usuario tras el proceso de cambio obligatorio de credenciales.

6. Plan de Acción

El presente plan de acción establece las medidas proactivas y preventivas necesarias para elevar la postura de ciberseguridad ante incidentes similares de *phishing* y compromiso de *endpoints*:

- **Reforzamiento de la Infraestructura de Correo:**
 - Implementar y auditar políticas estrictas de SPF, DKIM y DMARC para garantizar la autenticidad del origen de los correos electrónicos y bloquear dominios suplantados.
- **Endurecimiento de Endpoints (Hardening):**
 - Aplicar Políticas de Grupo (GPO) para restringir la ejecución de binarios desde carpetas temporales (`%TEMP%` , `AppData`).
 - Configurar restricciones de privilegios que impidan a usuarios estándar modificar la configuración del Firewall de Windows mediante PowerShell.
- **Optimización de Detección y Respuesta:**
 - Configurar reglas de correlación de alto nivel en el SIEM para alertar de inmediato cuando se cree un usuario nuevo y se añada al grupo de "Administradores".
 - Establecer un monitoreo de red para detectar actividad inusual de utilidades de red (`netcat` , `nmap`) hacia direcciones IP externas.
- **Cultura de Ciberseguridad:**

- Ejecutar simulacros de *phishing* dirigidos para capacitar a los colaboradores en la identificación de enlaces sospechosos y el uso de archivos con doble extensión.

7. Comunicado de Concienciación

Asunto: NOTIFICACIÓN DE SEGURIDAD: Detección de correos electrónicos fraudulentos

Estimado equipo de Terra,

El Departamento de Seguridad de la Información ha detectado recientemente una campaña activa de correos electrónicos fraudulentos que suplantán nuestra identidad corporativa. Estos correos utilizan técnicas de ingeniería social para solicitar la descarga de archivos adjuntos (como "Historial_Pagos_Visa.pdf.exe") bajo pretextos de urgencia.

Por su seguridad, le recordamos seguir estrictamente las siguientes medidas:

- **No ejecute adjuntos sospechosos:** El soporte técnico de Terra **nunca** enviará archivos ejecutables (.exe) por correo electrónico.
- **Verifique el remitente:** Desconfíe de cualquier correo que provenga de dominios externos o similares a los nuestros (ej. direcciones que terminan en **.co** o con caracteres inusuales).
- **Reporte inmediatamente:** Si recibe un correo con tono de urgencia o enlaces extraños, no haga clic y repórtelo inmediatamente a través del canal oficial: **seguridad@terra.com**.

La seguridad de nuestra red es una responsabilidad compartida. Agradecemos su colaboración para mantener nuestra infraestructura protegida.

Atentamente,

Equipo de Respuesta a Incidentes (Cybershield)